LAB 5: STATIC CODE ANALYSIS REPORT

Department of Computer Science and Engineering | Software Engineering Lab

Student Name: Ashwin Harish

SRN: PES1UG24AM900

Course: Software Engineering (SE) Lab

Deliverable: 4. Static Code Analysis Report

Assigned Program: 62_scramble (Word Scramble Arena)

GitHub Repository: https://github.com/ash29032006/L5_62_scramble

Date: October 23, 2026

1. Objective and Environment Setup

To enhance Python code quality, security, and style by utilizing static analysis tools (Pylint, Bandit, and Flake8) to detect and rectify common programming issues in the python script assigned (62_scramble) without executing the code.

Environment Configuration:

- Python 3.12.8, Pygame 2.6.1, Pylint 4.1.3, Bandit 1.9.4, Flake8 7.3.0
- Execution commands: bandit -r . > bandit_report_before.txt | flake8 . > flake8_report_before.txt | pylint main.py game/ > pylint_report_before.txt

2. Initial Static Analysis Findings (Before Remediation)

- **Bandit:** Found 2 issues (B105: heuristic password match on 'secret_word = ""'; B311: pseudo-random generators random.choice and random.shuffle unsuited for cryptographic security contexts).
- **Flake8:** Found 43 PEP 8 style issues (E501: lines > 79 characters; E302: expected 2 blank lines; W292: missing newline at end of file; F541: f-string without placeholders).
- **Pylint:** Rated code at **6.59 / 10** (Missing module/class/function docstrings C0114/C0115/C0116; high cyclomatic branching R0912 with 18 branches; oversized render method R0914/R0915 with 34 locals and 68 statements).

3. Identified Issues Table

The table below documents all detected findings, prioritizing security and structural issues first:

Issue	Type	Line(s)	Description	Fix Approach
B311: Insecure Pseudo-Random Generator	Vulnerability (Medium)	70	random.choice & random.shuffle use deterministic Mersenne Twister PRNG (CWE-330).	Replaced with secrets module (secrets.choice, secrets.SystemRandom().shuffle).
B105: Hardcoded Password / Credential	Vulnerability (Low)	12	self.secret_word = "" triggered Bandit B105 scanner due to 'secret' keyword heuristic.	Renamed attribute to target_word; exposed @property secret_word for compatibility.
R0912: Too Many Branches	Code Smell (Refactor)	124	handle_event contained 18 decision branches (limit 12) coupling inputs, clicks, drags.	Extracted mouse-down and mouse-up event handling into separate helper methods.
R0914 & R0915: Too Many Locals & Statements	Maintainability	209	The monolithic render method contained 34 local variables and 68 statements.	Decomposed render into modular helpers: _render_header, _render_timer_bar, _render_tiles, _draw_dragged_tile, _render_controls.
W1309 / F541: F-string Without Interpolation	Style / Warning	95	f"Hint revealed! (-1 point penalty)" was declared with 'f' prefix but lacked placeholders.	Removed 'f' prefix and converted to standard string literal.
E501: Line Length Exceeded (> 79 chars)	Style / PEP 8	Multiple	Over 35 lines in game_engine.py and text_box.py exceeded 79 characters boundary.	Wrapped method calls, coordinates, and tuples across multiple lines within 79 characters.

Issue	Type	Line(s)	Description	Fix Approach
E302: Expected Blank Lines	Style / PEP 8	3	In game/text_box.py, only one blank line separated imports from class TextBox.	Added second blank line before class definition.
W292: No Newline at End of File	Style / PEP 8	EOF	main.py, text_box.py, and game_engine.py lacked trailing newline at end of file.	Appended standard newline character to end of each file.
C0114, C0115, C0116: Missing Docstrings	Quality / Convention	1-333	Modules, classes, and methods lacked explanatory docstrings, lowering Pylint score.	Added PEP 257 compliant docstrings across all modules and methods (Pylint 10.00/10).

4. Step-by-Step Remediation (3 Commits)

- **Commit 1 (f43c6ba): fix(security): resolve Bandit security vulnerabilities (B105, B311)**
  Migrated to secrets module for secure randomness. Renamed secret_word attribute to target_word with backward-compatible property getters/setters. Verified clean Bandit scan (0 issues).
- **Commit 2 (c4d6cfb): style(pep8): resolve Flake8 style and formatting issues (E501, E302, W292, F541)**
  Wrapped all lines over 79 characters, added top-level blank lines, ensured final newlines, and removed redundant f-string prefixes. Verified clean Flake8 scan (0 errors).
- **Commit 3 (ab1a84d): fix(quality): resolve Pylint issues, achieve 10.00/10 score, and add lab deliverables**
  Added comprehensive docstrings across all files. Decomposed render() and handle_event() into modular helpers to eliminate excessive branches, locals, and statements. Verified perfect Pylint rating of 10.00/10.

5. Verification and Comparative Results (Before vs After)

Tool	Before Remediation	After Remediation	Status
Bandit	2 Issues (1 Medium: B311, 1 Low: B105)	0 Issues (Clean scan: No issues identified)	RESOLVED
Flake8	43 Violations (E501, E302, W292, F541)	0 Errors / 0 Warnings	RESOLVED
Pylint	Score: 6.59 / 10 (52 warnings/conventions)	Score: 10.00 / 10 (Target > 9.5 exceeded)	RESOLVED
Game Logic	Functional (bug fixed + 4 tasks)	Fully functional (tiles, timer, hints, scoring)	PASSED